

NETWORK SECURITY

Docente: Mg. Ing. Adolfo Cáceres Luque



Universidad
Tecnológica
del Perú

Introducción al Network Security

Unidad 1 – Semana 2



Universidad
Tecnológica
del Perú



Logro de la sesión



- ✓ Al finalizar la sesión el estudiante conocerá las diferentes metodologías de ataque en una red LAN.
- ✓ Utilizando laboratorios con máquinas virtuales se implementarán ataques de reconocimiento, ataques de acceso y ataques de denegación de servicio.

Temas a tratar

- Metodologías de ataque a una red LAN

Ataques por Malware

Existen diferentes puntos vulnerables en una red de datos, lo cual dependerá de los servicios que se presten a los usuarios.

Estos ataques de malware pueden:

- ✓ Crear una denegación de servicios de red (Dos, Ddos).
- ✓ Crear un acceso Remoto no autorizado (backdoors).
- ✓ Convertir al equipo en un proxy.
- ✓ Obtener datos desde el equipo de la víctima.
- ✓ Permitir para corrupción, eliminación y el cifrado de archivos.
- ✓ Aprovecharse de un servicio vulnerable (Vulnerabilidades).
- ✓ Detener o desactivar los programas antivirus y/o firewalls.



Virus

¿Cómo funciona?

Los virus se encuentran dentro de la categoría de *malware* y **están diseñados para copiarse a sí mismos y propagarse a tantos dispositivos como les sea posible.**



¿Cómo se propaga/infecta/extiende?

Proliferan infectando aplicaciones, a través del correo electrónico u otros servicios web, y pueden transmitirse por medio de dispositivos extraíbles, como memorias USB o archivos adjuntos, incluso a través de conexiones de red.

¿Cuál es su objetivo?

Pueden llegar a modificar o eliminar los archivos almacenados en el equipo. Son capaces de dañar un sistema, eliminando o corrompiendo datos esenciales para su correcto funcionamiento.

Adware

¿Cómo funciona?

Se trata de un **software malicioso** diseñado **para mostrarnos anuncios no deseados de forma masiva.**



¿Cómo se propaga/infecta/extiende?

Suelen instalarse junto a otros programas legítimos que, sin que nos percatemos, aceptamos y terminamos por instalar en el equipo.

¿Cuál es su objetivo?

Su objetivo es recopilar información sobre nuestra actividad y, de este modo, mostrarnos anuncios dirigidos. Suelen suponer más una molestia y un incordio. Sin embargo, su instalación también puede suponer una bajada de rendimiento y un mal funcionamiento del dispositivo. Además, suelen servir de enlace a sitios web maliciosos.

Troyanos

¿Cómo funciona?

Los troyanos *suelen camuflarse como un software legítimo para infectar nuestro equipo*, o a través de ataques de ingeniería social.



¿Cómo se propaga/infecta/extiende?

A menudo, se propagan por medio de archivos adjuntos en correos electrónicos o desde páginas webs poco fiables, escondiéndose tras descargas de juegos, películas o aplicaciones no legítimas. Nosotros, confiados, no somos conscientes de que nuestros equipos han sido infectados hasta que es demasiado tarde.

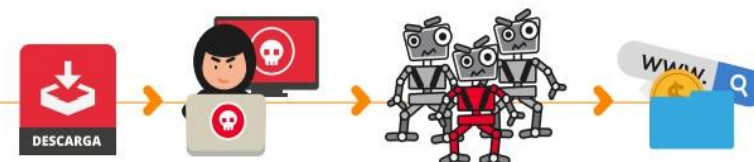
¿Cuál es su objetivo?

La mayoría de los troyanos tienen como objetivo controlar nuestro equipo, robar los datos, introducir más *software* malicioso en el equipo y propagarse a otros dispositivos.

Backdoors

¿Cómo funciona?

Una vez instalado en el sistema, permitirá al *ciberdelincuente tomar el control del equipo de forma remota*. Suelen utilizarse para infectar a varios dispositivos y formar una red zombi o *Botnet*.



¿Cómo se propaga/infecta/extiende?

A menudo, se propagan por medio de archivos adjuntos en correos electrónicos o desde páginas webs poco fiables, escondiéndose tras descargas de juegos, películas o aplicaciones no legítimas. Nosotros, confiados, no somos conscientes de que nuestros equipos han sido infectados hasta que es demasiado tarde. En ocasiones, se aprovechan de vulnerabilidades específicas de los sistemas o de nuestra conexión.

¿Cuál es su objetivo?

Su objetivo es conseguir crear una puerta trasera en nuestro sistema con la que controlar el equipo poco a poco y, finalmente, robar información o perpetrar otro tipo de ataques. Este tipo de *malware* tiene unas capacidades muy destructivas. Es capaz de monitorizar, registrar y compartir nuestra actividad con el atacante. Además, le permite crear, eliminar, editar y copiar cualquier archivo, así como ejecutar comandos y realizar modificaciones en el sistema.

Metodologías de Ataque

1.- Ataque de acceso:

- ✓ Ataques para descubrir contraseña (ataque de fuerza bruta)
- ✓ Ataque Man in The Middle
- ✓ Redirección de puerto lógico
- ✓ Desbordamiento de buffer

Para disminuir los ataques de acceso, se pueden utilizar los siguientes procedimientos:

- ✓ Utilizar contraseñas fuertes.
- ✓ Confianza mínima a los usuarios.
- ✓ Utilizar criptografía
- ✓ Parches y actualizaciones de los sistemas operativos y aplicaciones.



Metodologías de Ataque

Fuerza bruta

¿Cómo funciona?

Consiste en adivinar nuestra contraseña a base de ensayo y error. Los atacantes comienzan probando diferentes combinaciones con nuestros datos personales, en caso de conocerlos por otras vías. Luego, continúan haciendo combinaciones de palabras al azar, conjugando nombres, letras y números, hasta que dan con el patrón correcto.



¿Cuál es su objetivo?

El objetivo de los ciberdelincuentes siempre será conseguir la información almacenada en nuestras cuentas.

Dependiendo de si se trata de un correo electrónico, con el que obtener datos personales y contactos; una red social, con la que poder suplantar nuestra identidad; o datos bancarios, con los que llevar a cabo transferencias a su cuenta o realizar compras sin nuestro consentimiento, el atacante hará uso de esta información para su propio beneficio.

Ataque por diccionario

¿Cómo funciona?

Los ciberdelincuentes **utilizan un software que, de forma automática, trata de averiguar nuestra contraseña.** Para ello, realiza diferentes comprobaciones, empezando con letras simples como "a", "AA" o "AAA" y, progresivamente, va cambiando a palabras más complejas.



¿Cuál es su objetivo?

El objetivo de los ciberdelincuentes siempre será conseguir con la información almacenada en nuestras cuentas. Dependiendo de si se trata de un correo electrónico, con el que obtener datos personales y contactos, una red social, con la que poder suplantar nuestra identidad, o datos bancarios con los que llevar a cabo transferencias a su cuenta o realizar compras sin nuestro consentimiento, el atacante hará uso de esta información para su propio beneficio.

Metodologías de Ataque



2.- Ataque a las conexiones

1. Ataque de Reconocimiento

- ✓ Sniffers de paquetes (Wireshark, Tcpdump)
- ✓ Barridos de ping
- ✓ Escaneo de Puertos (Nmap, Legión)
- ✓ Búsqueda de información en Internet (footprinting)

Para disminuir estos tipos de ataque, se pueden utilizar los siguientes procedimientos:

- ✓ Implementar autenticación para evitar el acceso no autorizado.
- ✓ Utilizar cifrado para que los ataques que utilizan sniffers no logren resultados.
- ✓ Utilizar aplicaciones antisniffer.
- ✓ Utilizar firewalls e IPS.



Metodologías de Ataque

Escaneo de puertos

¿Cómo funciona?

El ataque de escaneo de puertos, o *portscan*, es el proceso en el que se analiza automáticamente los puertos de una máquina conectada a la red con la finalidad de analizar los puertos e identificar cuáles están abiertos, cerrados o cuentan con algún protocolo de seguridad.



¿Cómo se propaga/infecta/extiende?

Los ciberdelincuentes se sirven de varios programas con los que escanear los puertos de un router.

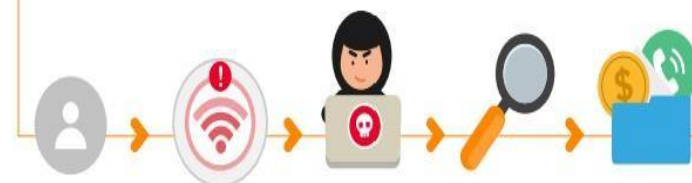
¿Cuál es su objetivo?

En este tipo de ataques, el objetivo suele ser el robo de nuestra información, como credenciales o datos bancarios, pero también ofrecen una entrada para controlar dispositivos conectados a una red.

Man in the middle

¿Cómo funciona?

Este tipo de ataque requiere que *el atacante se sitúe entre nosotros y el servidor con el que nos estamos comunicando*.



¿Cómo se propaga/infecta/extiende?

Suelen ser habituales en redes públicas o en redes wifi falsas localizadas en sitios públicos, como centros comerciales, aeropuertos u hoteles. El atacante consigue monitorizar la actividad online dentro de la red infectada.

¿Cuál es su objetivo?

Su objetivo es interceptar, leer o manipular los datos intercambiados, como mensajes, credenciales, transferencias económicas, etc. Generalmente, el atacante monitoriza nuestra actividad online y registra la información que más le interese.

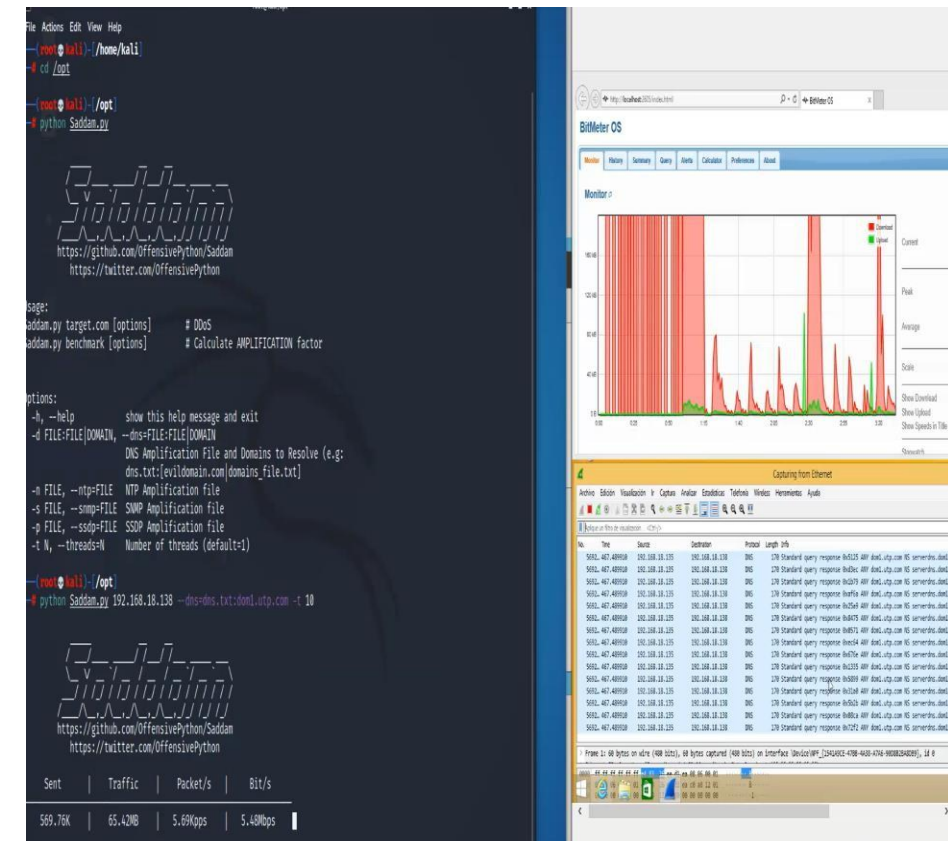
Metodologías de Ataque

2.2.- Ataque de denegación de Servicio.

- ✓ Un ataque de DoS puede hacer que se envíen paquetes de grandes tamaños que no son esperados por la aplicación receptora en la red.
- ✓ Un ataque de “Denegación Distribuida (DDoS)” es similar a un ataque DoS, excepto que un ataque Ddos se origina en múltiples fuentes coordinadas por la tanto es un ataque más sofisticado.

Algunas herramientas de denegación de servicios son:

- Ettercap
- Dos Attack, Saddam

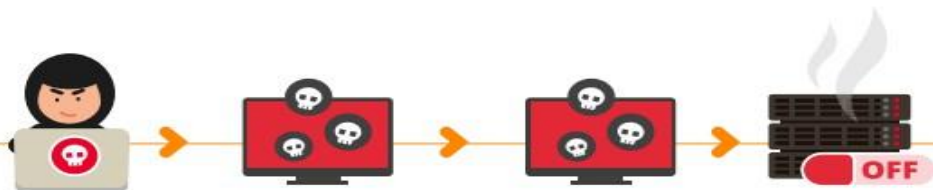


Metodologías de Ataque

Ataque DDoS

¿Cómo funciona?

DDoS son las siglas en inglés de “Ataque distribuido denegación de servicio” y **consiste en atacar un servidor web al mismo tiempo desde muchos equipos diferentes para que deje de funcionar** al no poder soportar tantas peticiones.



¿Cómo se propaga/infecta/extiende?

El ataque como tal no se propaga, sino que el ciberdelincuente o los ciberdelincuentes lanzan un ataque desde diversos dispositivos infectados. De hecho, la propagación se lleva a cabo a partir de otro tipo de ataques con los que infectar dispositivos e ir aumentando la potencia del ataque.



¿Cómo me protejo?

Como usuarios, si tenemos un servicio web, existen distintas técnicas de protección contra este tipo de ataque:

- **Monitorización continua:** Existen herramientas para analizar la actividad del sitio web y detectar posibles ataques DDOS antes de que se conviertan en un problema. El *firewall* puede ayudarnos a detectar posibles intrusos o una actividad fuera de lo normal.
- **Proveedor fiable:** Elegir un proveedor que nos ofrezca garantías, como un servicio de prevención o una infraestructura sólida para aguantar un intento de ataque.
- **Actualizaciones:** Las actualizaciones de seguridad nos protegerán de posibles vulnerabilidades en el *software*.
- **Conexión sólida:** Un buen ancho de banda nos ayudará a reducir los efectos de un ataque DDOS y a reponernos antes.
- **Reducir la superficie afectada:** Una solución muy útil es limitar la infraestructura de nuestro servicio web que pueda ser atacada, por ejemplo, redirigiendo el tráfico directo de Internet.

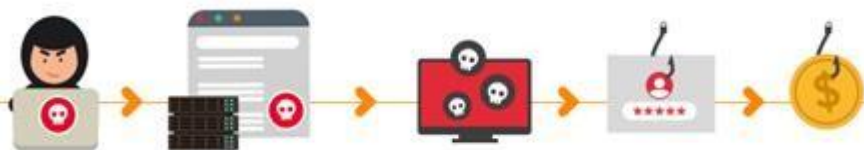
Metodologías de Ataque

Inyección SQL

¿Cómo funciona?

Las páginas webs suelen estar vinculadas a bases de datos, basadas en un lenguaje de programación conocido como SQL. Este tipo de ataque permite a los ciberdelincuentes insertar líneas de código SQL maliciosas en la propia aplicación web, obteniendo acceso parcial o completo a los datos, pudiendo ser monitorizados, modificados o robados por el atacante.

*SQL es un lenguaje de programación utilizado para interactuar con bases de datos. Los ciberdelincuentes **atacan a una aplicación web basada en este tipo de lenguaje, comprometiendo la base de datos mediante líneas de código malicioso.***



¿Cómo se propaga/infecta/extiende?

Los atacantes inyectan líneas de código SQL malicioso en la base de datos de las aplicaciones web. Para ello, se sirven de cualquier canal de entrada para enviar comandos maliciosos, como elementos *input*, cadenas de consulta, *cookies* y archivos.

¿Cuál es su objetivo?

El objetivo del atacante es tener acceso a los datos sensibles recogidos en la base de dato del servicio o aplicación web para robarlos o para destruirlos.

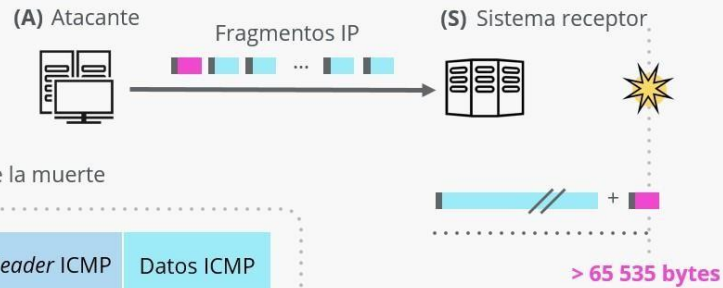
¿Cómo me protejo?

Como usuarios, **no podemos hacer mucho para prevenir este tipo de ataques, pues depende de la seguridad implantada por el servicio web.**

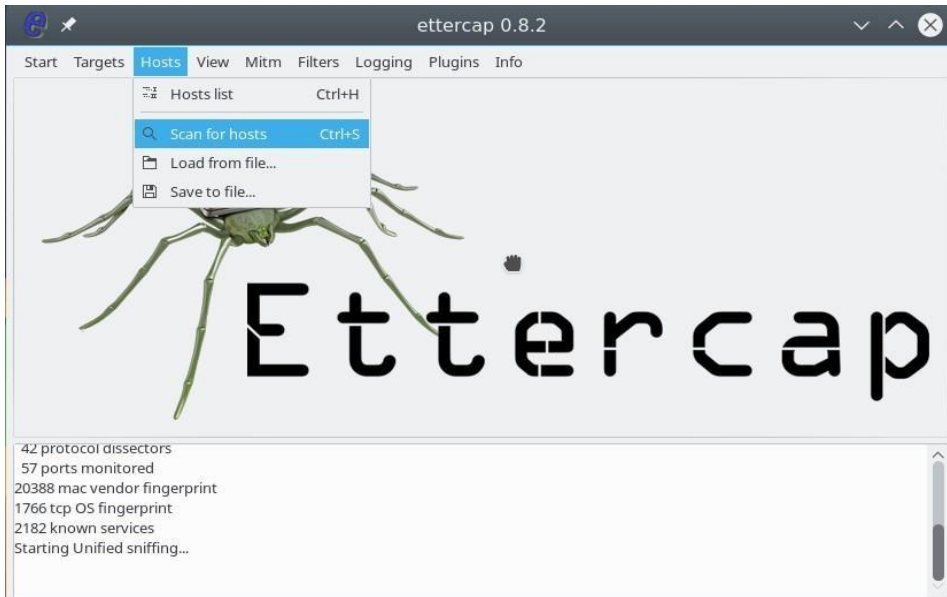
En el caso de los desarrolladores web, es fundamental que sigan las recomendaciones basadas en el diseño seguro y en el desarrollo de código seguro, que priorice la privacidad de las comunicaciones y la protección de nuestros datos.

Ping de la muerte

Mecánica



(P) Paquete ping de la muerte



```

root@kali: ~
File Edit View Search Terminal Help
root@kali:~# macof -i eth0 -d 192.168.1.1 -n 25
1a:5c:2a:21:c4:30 10:64:94:48:d2:3a 0.0.0.0.6061 > 192.168.1.1.32335: S 1214963868:1214963868(0) win 512
a4:da:ca:66:ea:ae 47:c5:a4:11:94:1d 0.0.0.0.58352 > 192.168.1.1.18233: S 1607629706:1607629706(0) win 512
e5:7d:c6:14:24:cc 3e:67:b9:21:ca:44 0.0.0.0.54181 > 192.168.1.1.46945: S 2104735317:2104735317(0) win 512
99:5b:b3:20:90:34 2e:3f:48:2c:84:7a 0.0.0.0.39995 > 192.168.1.1.10025: S 579553819:579553819(0) win 512
49:e5:8d:59:f6:ea bd:ac:9d:2f:e3:b9 0.0.0.0.35653 > 192.168.1.1.37071: S 146293057:146293057(0) win 512
4d:f3:72:1:32:91 41:1a:68:56:67:c1 0.0.0.0.48334 > 192.168.1.1.51007: S 1380357730:1380357730(0) win 512
e0:62:25:3b:a:20 d3:e2:f3:22:74:87 0.0.0.0.14935 > 192.168.1.1.62106: S 1955045972:1955045972(0) win 512
f3:b9:32:55:4:be 13:88:bf:50:7a:c2 0.0.0.0.17353 > 192.168.1.1.40661: S 714083375:714083375(0) win 512
9e:58:7d:51:0e:c7 63:83:c5:36:68:3f 0.0.0.0.52059 > 192.168.1.1.12306: S 841927560:841927560(0) win 512
c4:ac:1c:40:16:c8 48:c:9b:4b:de:3e 0.0.0.0.63469 > 192.168.1.1.50340: S 1214784809:1214784809(0) win 512
6d:9e:8f:60:7b:e0 30:b2:ef:78:28:eb 0.0.0.0.26917 > 192.168.1.1.50171: S 1463474914:1463474914(0) win 512
41:5c:84:2b:f2:50 ec:95:d4:6:f4:f7 0.0.0.0.25679 > 192.168.1.1.12029: S 1557020264:1557020264(0) win 512
78:df:0:1e:88:ea 39:53:1d:4b:b3:6c 0.0.0.0.58908 > 192.168.1.1.50327: S 553841988:553841988(0) win 512
ed:41:98:7a:ec:da cf:f2:4b:47:c9:d0 0.0.0.0.39575 > 192.168.1.1.31722: S 417803307:417803307(0) win 512
4c:2f:c3:35:e9 58:bd:fe:7e:f:cb 0.0.0.0.3401 > 192.168.1.1.26576: S 2105576263:2105576263(0) win 512
1c:64:4:68:e5:ba 7:8f:c6:33:be:ec 0.0.0.0.11606 > 192.168.1.1.35605: S 1127080421:1127080421(0) win 512
5:1e:7e:53:aa:69 8d:f:79:b:d:3e 0.0.0.0.62962 > 192.168.1.1.63528: S 532076354:532076354(0) win 512
24:6c:9c:26:e2:f2 d7:3c:17:58:fa:9c 0.0.0.0.7677 > 192.168.1.1.22865: S 1601291153:1601291153(0) win 512
fe:d6:9b:f:d3:8a a7:45:f1:71:f1:6e 0.0.0.0.29310 > 192.168.1.1.45502: S 1631937134:1631937134(0) win 512
aa:95:6a:49:c8:ce 20:61:cf:6e:d3:e3 0.0.0.0.47513 > 192.168.1.1.65242: S 1396026148:1396026148(0) win 512
67:80:66:74:82:f6 68:1:5b:55:aa:c4 0.0.0.0.18854 > 192.168.1.1.55704: S 1642087517:1642087517(0) win 512
66:9b:2f:5c:8e:7f be:aa:dd:19:66:a6 0.0.0.0.53102 > 192.168.1.1.56830: S 628043691:628043691(0) win 512
22:8e:5a:42:d9:6 53:96:c3:53:59:7b 0.0.0.0.14559 > 192.168.1.1.52041: S 1024789677:1024789677(0) win 512
2a:13:b9:71:9d:48 63:a2:22:55:ad:64 0.0.0.0.28168 > 192.168.1.1.47984: S 611048874:611048874(0) win 512
5c:1b:ba:69:ae:db 22:66:66:37:af:26 0.0.0.0.7447 > 192.168.1.1.60234: S 1558813890:1558813890(0) win 512

```

Metodologías de Ataque

3.- Ataque por Ingeniería social

- ✓ Los ataques por ingeniería social se basan en un conjunto de técnicas dirigidas a nosotros, los usuarios, con el objetivo de conseguir que revelemos información personal o permita al atacante tomar control de nuestros dispositivos.
- ✓ Existen distintos tipos de ataques basados en el engaño y la manipulación, aunque sus consecuencias pueden variar mucho, ya que suelen utilizarse como paso previo a un ataque por malware.

Dumpster Diving

¿Cómo funciona?

En ciberseguridad, *se conoce como el proceso de "buscar en nuestra basura" para obtener información útil sobre nuestra persona o nuestra empresa* que luego pueda utilizarse contra nosotros para otro tipo de ataques.



¿Cómo se propaga/infecta/extiende?

No dispone de un medio de propagación, pero está dirigido principalmente a grandes organizaciones o a individuos en concreto de los que se pueda obtener información sensible. El usuario afectado podría haber tirado a la basura documentos importantes o información personal muy valiosa para un atacante.

¿Cuál es su objetivo?

Su objetivo son documentos, anotaciones y demás información sensible que hayan podido tirar a la basura por descuido, como números de tarjetas de crédito, contactos, anotaciones con credenciales, etc.
También buscan dispositivos electrónicos desechados a los que acceder y sacar toda la información que no haya sido borrada correctamente.

Metodologías de Ataque

¿Cómo funciona?

La ingeniería social es utilizada frecuentemente para llevar a cabo todo tipo de fraudes y estafas online con las que engañarnos a los usuarios para que revelemos nuestros datos personales, o con las que obtener un beneficio económico a nuestra costa.

Existen una gran variedad de fraudes, y sus objetivos y medidas de protección pueden variar de un tipo a otro. **Para aprender a identificarlos y a actuar ante ellos, la OSI pone a nuestra disposición una guía para aprender a identificar fraudes online**, donde se incluye: falsos préstamos, tiendas online fraudulentas, falsos alquileres, falso soporte técnico, sextorsión y muchos otros.



Metodologías de Ataque

Phishing, Vishing y Smishing

¿Cómo funciona?

Se tratan de tres **ataques basados en ingeniería social muy similares en su ejecución**. De forma general, el ciberdelincuente **enviará un mensaje suplantando a una entidad legítima**, como puede ser un banco, una red social, un servicio técnico o una entidad pública, con la que nos sentimos confiados, **para lograr su objetivo**. Estos mensajes suelen ser de carácter urgente o atractivo, para evitar que apliquen el sentido común y se lo piensen dos veces.



Phishing

Suele emplearse el correo electrónico, redes sociales o aplicaciones de mensajería instantánea.

Vishing

Se lleva a cabo mediante llamadas de teléfono.

Smishing

El canal utilizado son los SMS.

Spam

¿Cómo funciona?

Consiste en el **envío de grandes cantidades de mensajes o envíos publicitarios a través de Internet sin haber sido solicitados**, es decir, **se trata de mensajes no deseados**. La mayoría tienen una finalidad comercial, aunque puede haberlos que contengan algún tipo de *malware*.



¿Cómo se propaga/infecta/extiende?

El canal más utilizado sigue siendo el correo electrónico, pero se sirve de cualquier medio de Internet que permita el envío de mensajes, como las aplicaciones de mensajería instantánea o las redes sociales.

¿Cuál es su objetivo?

Los objetivos son muy variados. Desde el envío masivo de mensajes publicitarios, hasta maximizar las opciones de éxito de un ataque de tipo *phishing* a una gran población, o tratar de infectar el mayor número posible de equipos mediante *malware*.

Conclusiones



1. Aplicar la seguridad en las redes actualmente evita muchas pérdidas económicas y de activos de información valiosa para la organización.
2. Aplicar la seguridad en redes y conocer los tipos de virus existentes ayuda a minimizar los riesgos en una organización.
3. Conocer las medidas preventivas y correctivas frente a un ataque cibernético ayuda a la organización ante un riesgo de ataque y fuga de la información.

Actividad



1. Demostrar un ataque de acceso por fuerza bruta basado en diccionario de datos.
2. Demostrar un ataque de fingerprinting.
3. Demostrar un ataque de reconocimiento.
4. Demostrar un ataque de denegación de servicios
5. Demostrar un ataque de ARP Spoofing

Gracias!

Desaprende lo que te limita



**Universidad
Tecnológica
del Perú**